Concepts et politiques de sécurité

CE QUE L'EXAMEN ATTEND

Définir menaces, vulnérabilités, exploits et mesures d'atténuation ; décrire un programme de sécurité et les politiques de mots de passe, MFA, certificats et biométrie compris.

01 L'ESSENTIEL

01 Vulnérabilité : faiblesse d'un système. Exploit : méthode ou code qui l'utilise. Menace : danger qu'un acteur exploite cette faiblesse. Atténuation (mitigation) : mesure qui réduit la probabilité ou l'impact. Objectifs : confidentialité, intégrité, disponibilité (CIA).

02 Attaques courantes : DoS et DDoS, usurpation (spoofing), réflexion et amplification, man-in-the-middle, reconnaissance, malware (virus, ver, cheval de Troie, rançongiciel), ingénierie sociale (phishing, spear phishing, whaling, vishing, smishing), attaques sur les mots de passe.

03 Programme de sécurité : sensibilisation de tous les utilisateurs (user awareness), formation adaptée aux rôles (training), contrôle d'accès physique (badges, serrures, vidéosurveillance, locaux techniques fermés).

04 Politique de mots de passe : longueur minimale, refus des mots de passe connus ou réutilisés, changement en cas de compromission, gestionnaire de mots de passe, verrouillage après échecs répétés.

05 MFA (authentification multifacteur) : facteurs de catégories différentes. Certificat numérique : clé publique liée à une identité et signée par une autorité de certification (CA). Biométrie : pratique, mais non révocable en cas de fuite.

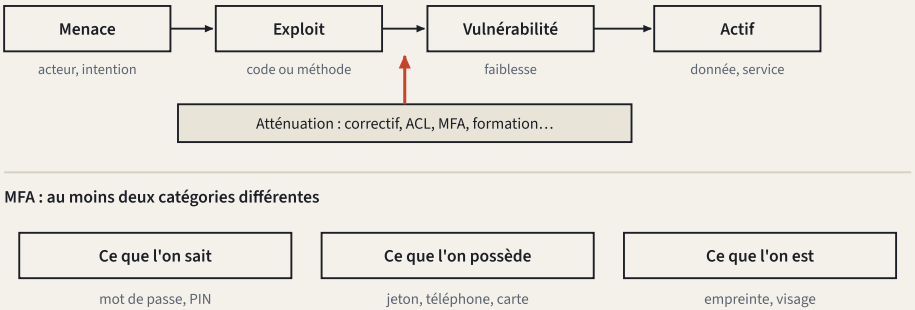


FIG. 31 L'atténuation agit sur la vulnérabilité ou sur l'exploit. Deux éléments de la même catégorie ne forment pas une MFA.

02 COMMANDES CLÉS

COMMANDE	RÔLE
`R1(config)# security passwords min-length 10`	Longueur minimale imposée
`R1(config)# login block-for 120 attempts 3 within 60`	Blocage 120 s après 3 échecs en 60 s
`R1(config)# login on-failure log`	Journalise les échecs
`R1# show login`	VÉRIF. État du blocage
`R1# show login failures`	VÉRIF. Tentatives échouées

03 PIÈGES D'EXAMEN

P1 Mot de passe et code PIN : un seul facteur (deux éléments que l'on sait).

P2 Une vulnérabilité peut exister sans exploit connu ; l'exploit, lui, suppose une vulnérabilité.

P3 Phishing : envoi massif. Spear phishing : cible précise. Whaling : dirigeant visé.

04 AUTO-TEST

1 Quelle combinaison constitue une authentification multifacteur ?

A. Mot de passe + PIN
B. Mot de passe + question secrète
C. Carte à puce + empreinte
D. Deux mots de passe

2 Comment nomme-t-on le code qui tire parti d'une faiblesse logicielle ?

A. Exploit **B.** Menace **C.** Vulnérabilité **D.** Atténuation

3 Quel élément du programme de sécurité rappelle régulièrement les risques à tous les employés ?

A. Contrôle d'accès physique
B. Sensibilisation des utilisateurs
C. Pare-feu
D. Chiffrement

REPÈRE Savoir, avoir, être : une MFA puise dans deux catégories.

RÉPONSES **1 C** Carte (possession) et empreinte (biométrie) : deux catégories différentes.
2 A L'exploit utilise la vulnérabilité ; la menace en est le danger potentiel.
3 B User awareness : messages et campagnes destinés à tous ; le training cible des rôles.